DIB: Managing Local MUD Policy Lifecycles with Shared IoT Traffic Evidence

Anonymous Authors

***Abstract*—Shared IoT traffic observations can help administrators create Manufacturer Usage Description (MUD) policies when manufacturer profiles are unavailable or outdated. In the event of compromise, their lifecycle may require coordinated withdrawal while preserving local control over permissions.**

This paper presents Device Intent Blueprint (DIB), a framework designed to facilitate the creation and sharing of MUD policies by separating shared traffic evidence from local authorization. Candidate communications enter a review queue and generate MUD rules only after local approval. A shared dispute triggers coordinated withdrawal while local decisions are preserved. DIB records the approval validity and the origin of revocation, allowing disconnected sites to reconcile even after missing an entire withdrawal-and-restoration episode.

We evaluate DIB through exhaustive lifecycle model checking, an OpenWrt/osMUD testbed, and experiments on three IoT traffic datasets. The results show that DIB works as intended: it preserves local authorization during coordinated withdrawal and recovery, reconciles disconnected sites in about 70 ms on average in the evaluated deployment, and supports flexible candidate selection. Overall, the tests confirm that DIB works as intended, with reconciliation taking about 70 ms on average in the evaluated deployment.

***Index Terms*—IoT security, Manufacturer Usage Description, distributed network management, access policy management, policy lifecycle.**

I. Introduction

Internet of Things (IoT) devices rely on network services for updates, remote control, and data exchange. Restricting their communications to the services they need can limit their exposure and the network activity of compromised devices [1], [13]. To support this approach, the Internet Engineering Task Force (IETF) standardized Manufacturer Usage Description (MUD) in RFC 8520 [6]. This standard involves MUD files, describing a device's intended communications, and MUD managers, which translate this description into access-control rules for the local networks.

Since manufacturer profiles may be unavailable or become outdated as firmware and cloud services change [13], [33], traffic observations can help administrators draft or update these profiles, and reports from other networks provide additional evidence when local observations remain limited. However, a service used in one network may be unnecessary in another, and observed traffic may include communications generated by compromised devices [1], [33]. Therefore, administrators must decide which proposed rules to apply in their own networks.

These decisions are part of a policy lifecycle. For instance, considering a camera without a manufacturer profile: two networks observe the same cloud service, and an administrator uses their reports to approve a local rule. If a contributor later disputes that service, the participating networks must withdraw the associated permissions. Once the dispute is resolved, the system must distinguish dispute-induced withdrawal from independent local revocation. It must preserve this distinction when reconciling a network that was disconnected throughout the episode.

To overcome this limitation, this paper proposes *Device Intent Blueprint (DIB)*, a framework for managing locally authorized MUD policies based on shared IoT traffic observations. We call each independently administered network a *site*. DIB groups observations into *endpoint facts*, each of which identifies a (i) device type, (ii) communication direction, (iii) protocol, (iv) peer, and (v) port. The observations and contributor reports supporting a fact form its *evidence*, and a *registry* stores that evidence alongside separate records of each site's policy decisions.

DIB separates candidate selection from authorization. Selected facts enter the MonitorOnly state, where administrators can review them without creating MUD rules. Once an administrator approves locally, a fact is moved to the active state, and it can be exported to other sites. A shared dispute invalidates approvals; restoration requires renewed review and preserves local revocations. Ordered updates reconcile sites that missed intermediate changes.

Existing approaches cover profile extraction, evidence sharing, and coordinated authorization. DIB addresses recovery across independent authorities by combining deny-overrides and a last-writer-wins pending register with explicit approval validity and revocation origin. Together, these records determine whether a recovering site must return a fact to review or retain an independent local veto.

To conclude, the main contributions of this paper are: (1) a policy lifecycle and reconciliation mechanism that preserves local authorization during shared withdrawal and recovery, including after missed episodes; (2) a registry and distributed prototype, evaluated through finite-state verification, controlled ablations, recovery experiments, and OpenWrt/osMUD enforcement; (3) a matched evaluation on three IoT traffic datasets that distinguishes the effects of candidate admission and review ordering.

II. Related Work

RFC 8520 leaves the local application of MUD recommendations to the network administrator and calls for policy updates to respect deployment-specific approval flows [6, Secs. 1.1 and 1.8]. A parallel IETF effort standardizes MUD

URL reissuance [37], which addresses authority over manufacturer URL updates. DIB governs operator-approved facts derived from traffic observations. Prior work extracts or enforces profiles from local traffic within one administrative domain [7], [9]–[12], [18] rather than governing observations shared across domains.

Threat-intelligence sharing platforms (MISP, STIX), contributor reputation systems [19]–[22], and collaborative IoT learning (CoLearn, DÏoT, IoT Inspector) [15]–[17], [32] aggregate evidence, traffic models, or anomaly reports. These approaches share information rather than grant network access, and therefore specify no withdrawal semantics for permissions already installed at a recipient.

Policy-based management and intent frameworks address policy specification, conflicts, and configuration [23]–[28]. POLARIS [35] lets resource owners decide access from verifiable attributes and binds access to sessions. FIDEM [34] verifies device–MUD-class binding and propagates profile updates through URL reissuance or signature-change checks. Their workflows address identity-based access and profile authenticity, respectively. DIB assumes established identities and specifies how shared withdrawal invalidates per-site approvals, how restoration preserves local vetoes, and how sites reconcile after missed episodes. Dynamic and security-tested MUD profiles [14], [29] also motivate profile evolution.

The deny-overrides combining rule in XACML and policy frameworks [38] resolves conflicting decisions during policy evaluation. DIB retains the origin of a revocation across updates so that a shared restore preserves a local denial. Zanzibar [36] addresses stale authorization through consistency tokens in a globally coordinated service, where one authority both grants and revokes. DIB propagates withdrawal to sites that grant permissions independently and reconciles unreachable sites after reconnection. Its pending target follows a last-writer-wins register [39], with local guards preserving revocation origin.

Paragrafo qui in cui enfatizzi in cosa DIB è diverso/migliore e cosa pensi possa portare alla community scientifica.

III. System Model, Design Goals, and Threat Model

We consider a closed consortium of independently administered sites. Each site has a local operator, a MUD manager, and a gateway. Sites send traffic observations to a shared *evidence service*, which holds the shared part of the registry, selects candidate endpoint facts, and distributes lifecycle updates such as disputes and restorations; each site keeps its own decisions (Fig. 1).

A. Design Goals

Each goal is stated with the observation that would refute it.

- **G1: Evidence-based proposals.** For a device type whose manufacturer profile is unavailable or outdated, a site receives candidate endpoint facts derived from other sites' observations, and fewer candidates reach review than the facts reported in total. *Refuted if* shared proposals match the receiver's traffic no better than its own observations at cold start, or if candidate selection does not reduce the review volume.
- **G2: Conditional admission protection.** A fact enters a site's review queue only if its shared evidence passes an admission rule. If malicious contributors make up at most a bounded fraction of the sites that observe a device type (assumption AS2 below), no fact reported only by them passes the rule. Passing does not establish that a communication is benign or necessary. *Refuted if* a fact reported only by malicious contributors within that bound is admitted.
- **G3: Local authorization with conservative withdrawal.** In every reachable state, a fact produces a MUD rule at a site only if that site's operator approved it and no later dispute or restoration has voided the approval; nothing shared creates an approval, and local actions never change another site's records. A dispute removes the rule at every site, upon reconciliation if the site is unreachable; a restoration returns the fact to review and preserves local revocations, also at sites that missed the episode. *Refuted by* a rule without a valid approval, a peer record changed by a local action, a disputed fact exported after reconciliation, or a local revocation erased by a restoration.

G3 is a lifecycle invariant, formalized as I1–I3 in Sec. IV-B; it imposes no deadline on withdrawal, and Sec. VI-C measures how long withdrawal takes at reachable sites under emulated delay and loss. G1 and G2 concern candidate selection, which affects what operators review but never what a gateway enforces. Sections VI-A, VI-B, and VI-C test G3, Sec. VI-E G1, and Sec. VI-F G2.

B. Roles, Trust Boundary, and Assumptions

Members submit observations, read their own candidates, and send *dispute notices*, i.e., requests to withdraw a fact. Each site's operator alone approves, revokes, and restores facts at that site. A consortium administrator alone performs global restoration after a dispute. The evidence service aggregates evidence, selects candidates, and orders and distributes lifecycle updates; it is trusted for this, not to authorize. Each site's MUD manager and gateway apply only that site's policy.

The boundary of each site's administrative domain (dashed boxes in Fig. 1) is the only place where authorization is created. Inputs that cross it from outside, such as observations, candidates, disputes, and restorations, can at most place a fact in review or withdraw its rule; they cannot install a rule. The goals rely on six assumptions:

- **AS1 (Authenticated identities and roles).** Every request is bound to an identity and the role rules above are enforced, e.g., through mutual Transport Layer Security (TLS) with X.509 certificates bound to site identifiers. The finite models and lifecycle experiments use trusted caller identities, so G3 holds conditionally on AS1.
- **AS2 (Bounded per-type malicious share).** For every device type d, the sites whose reports for d are malicious—colluding members and honest sites that report the traffic of compromised devices—make up at most a fraction f_s of the sites contributing evidence for d (formalized in Sec. IV-C).

Because that population is derived from submitted evidence, membership governance must verify which device types each member operates; the prototype does not perform this check. Only G2 depends on AS2.

- **AS3 (Aligned labels).** Sites map device labels to common device types before submitting evidence.
- **AS4 (Trusted local domain).** A site's operator, MUD manager, and gateway act on behalf of that site; misuse of a local approval or revocation is an insider action.
- **AS5 (Policy authority).** A gateway applies only policies signed by its own site's authority, whose key neither peers nor the evidence service hold; the testbed uses unsigned policies (Sec. V).
- **AS6 (Eventual delivery).** Every site eventually reconnects and retrieves the updates it missed, after an unbounded time; network faults lose messages but do not forge them.

C. Adversary Model

The adversary may control colluding members, which submit arbitrary observations and dispute notices; compromise devices inside honest sites; obtain extra identities when membership control fails; and disconnect sites for finite periods. It cannot impersonate a member (AS1), act as an operator (AS4), or sign a site's policy (AS5). We consider four threats: (i) **A1 (Poisoned observations)**: an honest site reports real flows of a compromised device; (ii) **A2 (Fabricated evidence)**: members report traffic that did not occur, within the share of AS2 or, in stress tests, with fabricated identities beyond it; (iii) **A3 (Low-and-slow drift)**: device behavior changes gradually across sites, so legitimate and malicious change produce the same observations; and (iv) **A4 (Dispute abuse)**: members send unfounded dispute notices to withdraw legitimate rules. A1 and A2 target G2, A3 targets G1 and G2, and A4 targets availability. Disconnections are faults covered by AS6. Section IV-D relates each threat to the mechanisms that address it.

Out of scope. We do not address misuse by a site's own administrator (AS4); compromise of a certificate authority or of a signing key; the quality of operator decisions; confidentiality of shared evidence; binding of a physical device to its device type; denial of service against the evidence service; a time bound for withdrawal; or traffic whose peer names are hidden by encrypted DNS or Encrypted Client Hello (Sec. VII).

IV. Proposed Approach

DIB comprises a shared evidence service and independently administered site services (Fig. 1). The evidence service receives observations and distributes candidates and ordered lifecycle updates. Each site retains its decisions, operator interface, and MUD exporter. Its service applies shared updates, preserves local revocations, and exports approved endpoint facts to the MUD manager.

A. Records and Operational Flow

For device type d, an endpoint fact is $f = (d, e)$, where $e = (\text{direction}, \text{protocol}, \text{peer}, \text{port})$. The peer is a Fully Qualified Domain Name (FQDN) or remote IP address. Before scoring, adapters associate observed names with addresses and normalize protocol labels. Names come from DNS records or HTTP/TLS metadata, depending on the dataset; the remaining fields come from the flow's direction, protocol, and port. Scoring uses outbound communications because the evaluated captures predominantly contain device-initiated traffic. The exporter can also generate return-flow entries.

The *DIB registry* is the logical record model for shared evidence and per-site decisions. The single-registry implementation stores both in one service. In the distributed prototype, the shared evidence service holds only shared records; each site stores its own decisions (Sec. VI-B). Shared records contain observations, reporting sites, timestamps, and attestations. The contribute operation deduplicates submissions; attest records a positive site assessment. *Local* evidence fails admission; *Corroborated* evidence meets the endpoint, reporting-site, score, and dispute checks for review (Sec. IV-C). Three distinct positive attestations promote an undisputed Corroborated record to *Consortium-attested*. These labels establish neither benignity nor permission to communicate.

Site-local records hold decisions and their revision history. A QUERY stages an admissible fact as MonitorOnly if the site has no record, or returns its existing decision; it is therefore not a read-only operation. MonitorOnly places a proposal in the operator's review queue without generating a network rule. Local approval is recorded through OPERATOR-COMMIT (a local commit), the only operation that authorizes export. Decision history records lifecycle events and the resulting state, actor, time, and reason where supplied, allowing restoration to distinguish a local veto from shared withdrawal.

From observations to a MUD rule. To provide an example of an observation that could become an endpoint fact, we can assume having two different sites (A and B), both having inside their network an IP Camera. In this example, the two sites report TCP traffic to `api.vendor.example` on port 443. Once admitted, the fact enters site A's review queue as MonitorOnly. An OPERATOR-COMMIT moves it to Active, and the exporter emits an access-control entry (ACE) matching the destination DNS name and TCP port in the from-device access-control list (ACL), which the MUD manager resolves and installs. Site B requires its own approval. Table I summarizes the outcomes of this example. On the other side, withdrawal regenerates the site's policy, which the gateway must apply to remove installed permissions. Table II specifies the recovery transitions.

TABLE I
ILLUSTRATIVE RECORDS AND EXPORT FOR THE CAMERA EXAMPLE. FIELD GROUPS SUMMARIZE STORED INFORMATION, NOT AN API SERIALIZATION.

Record	Example contents
Endpoint fact	(camera, out, TCP, `api.vendor.example`, 443)
Evidence	Reporters: sites A and B; observation timestamps and counts; computed admission score
Site A decision	Active after A's commit; valid approval; commit event in decision history
Site B decision	MonitorOnly; no approval; no exported rule
Site A MUD ACE	Destination DNS name `api.vendor.example`; IP protocol 6; TCP destination port 443; forwarding accept

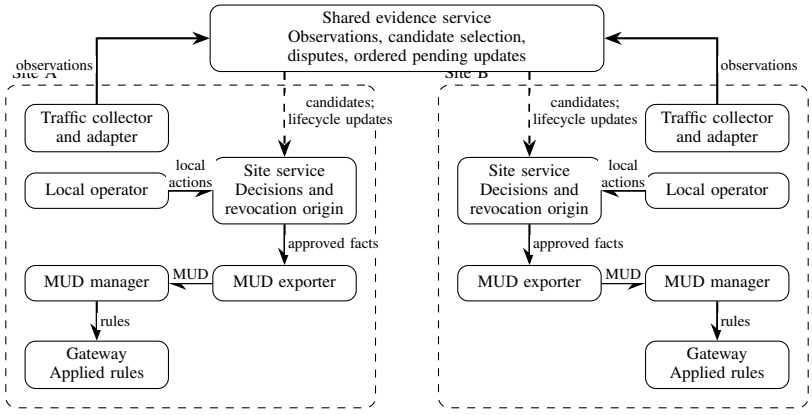


Fig. 1. DIB's distributed architecture. Dashed boxes delimit local administrative authority. Solid arrows carry observations, local decisions, and policy output; dashed arrows carry shared candidates and lifecycle updates, which disconnected sites retrieve on reconnection. The MUD manager and gateway may be co-located, as in the OpenWrt testbed.

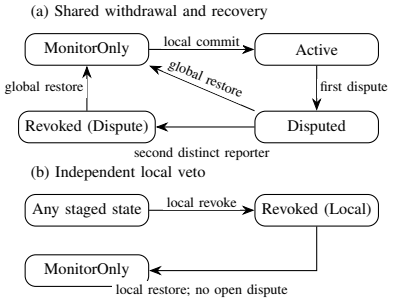


Fig. 2. Recovery paths for an admitted fact. A local veto can be recorded from MonitorOnly, Active, Disputed, or Revoked (Dispute), and survives global restore. Panel (a) shows withdrawal from Active; all guards are in Table II.

B. Site-Local Authority Lifecycle

Figure 2 summarizes all the possible transitions that an endpoint fact f can assume during its lifecycle inside a site s. Indeed, an endpoint fact can reside only in one of the five authorization states:

$$S = \{\text{Absent}, \text{MonitorOnly}, \text{Active}, \text{Disputed}, \text{Revoked}\}.$$

Revoked (Dispute) and Revoked (Local) share the state Revoked, but differ in the separately stored revocation origin. Each local approval enters Active and creates a fresh *grant*, tracked by `grantValid`$[s][f]$. Export requires both:

$$\begin{aligned}\text{Exportable}(s,f) \iff\ & \text{state}(s,f) = \text{Active} \\ \wedge\ & \text{grantValid}(s,f).\end{aligned} \tag{1}$$

Table II gives the transitions and guards, which also depend on grant validity, dispute status, and revocation origin.

Review candidates are not permanent: a MonitorOnly record with no prior operator action returns to Absent once its evidence has stayed below admission for the retention window W, bounding queue growth without touching any record carrying a local decision. A local veto can be recorded from Active, MonitorOnly, Disputed, or dispute-derived Revoked. It changes only the receiving site's record and survives dispute confirmation and global restoration. Local restore remains blocked while a shared dispute is open. Once the dispute is resolved, local restore returns the record to review; export requires a fresh local commit.

Core Invariants (I1–I3). Under the stated identity assumptions, the lifecycle requires:

- **(I1) Fresh Local Authorization:** Only operator-commit by site s's operator can move fact f into Active and create a valid grant at that site.
- **(I2) Site Confinement:** Local commit, revoke, and restore at site s leave every peer site's records unchanged.
- **(I3) Conservative Reversal:** A dispute invalidates grants and export eligibility at reachable sites during fan-out and at other sites upon reconciliation. Restoration requires fresh local approval and preserves independent local revocations, including those recorded at sites that missed the entire dispute/restore episode. No timing bound is imposed on reconciliation.

Export control. Equation 1 gates export on current local authorization, and verification checks that commit, dispute, restore, and reconciliation maintain it across their interleavings. The mutations in Table VI isolate failures of grant coherence, site confinement, veto preservation, and export control. Gateway application follows export, so an unreachable gateway can retain an older policy until reconnection.

C. Candidate-Selection Policy

The prototype uses automatic admission to limit the proposals presented for local review. We define the admission rule, its score, and the component checks below. Table III lists the parameters. The alternative selection policies evaluated in Section VI change the review queue while retaining the same local approval and recovery rules.

Combined rule: Automatic staging requires endpoint eligibility, at least m reporting sites, score at least θ, and no unresolved dispute. The quorum counts distinct reporting identities, which need not be independent observers; Table IV justifies its value:

$$\begin{aligned}\text{admit}_{auto}(d,e) = (A(d,e) = 1) \wedge (|S_{d,e}| \geq m) \\ \wedge\ (score(d,e) \geq \theta) \\ \wedge\ \neg openDispute(d,e).\end{aligned} \tag{2}$$

Passing permits staging, not export, and does not override existing local decisions (Sec. IV-A).

TABLE II

LIFECYCLE TRANSITIONS. PARENTHETICAL LABELS ON REVOKED INDICATE REVOCATION ORIGIN; SLASHES SEPARATE ALTERNATIVE SOURCE STATES. REPEATED REPORTS FROM THE SAME SITE AND REPORTS AFTER CONFIRMED REVOCATION ADD NO TRANSITION. OTHER UNDEFINED TRANSITIONS ARE REJECTED OR LEAVE THE RECORD UNCHANGED. RETENTION EXPIRY IS SPECIFIED HERE BUT LIES OUTSIDE THE VERIFIED CONFIGURATION.

Current state	Event	Precondition	Next state	Grant valid?	Exportable?
Absent	query/stage	admitted; no open dispute	MonitorOnly	no	no
MonitorOnly	local commit	local operator; no dispute	Active	yes, new	yes
MonitorOnly/Active	first dispute	valid dispute	Disputed	no	no
Disputed	second dispute	distinct reporting site	Revoked (Dispute)	no	no
Disputed/Revoked (Dispute)	global restore	authorized restore	MonitorOnly	no	no
Active/MonitorOnly/Disputed/Revoked (Dispute)	local revoke	local operator	Revoked (Local)	no	no
Revoked (Local)	local restore	no open dispute	MonitorOnly	no	no
MonitorOnly	retention expiry	below admission for window W; no local decision	Absent	no	no
Revoked (Local)	global restore	—	Revoked (Local)	no	no
Absent	dispute	—	Absent	no	no

TABLE III

ADMISSION NOTATION AND OPERATING VALUES (d: DEVICE TYPE; e: ENDPOINT). C_s IS RAW BREADTH UNLESS AN EXPERIMENT STATES TRUST WEIGHTING.

Symbol	Meaning	Value
ES_d	sites with ≥ 1 observation of device type d	—
$S_{d,e}$	subset of ES_d reporting endpoint (d, e)	—
C_s, C_t	cross-site breadth; temporal confidence	—
m	minimum reporting sites (quorum)	2
θ	admission threshold	0.65
α, β	breadth / temporal weight, $\alpha + \beta = 1$	0.6, 0.4
f_s	assumed per-type adversarial raw-breadth share (budget)	0.30

Admission score. With nonnegative weights α, β for breadth and temporal confidence,

$$score(d, e) = \alpha C_s(d, e) + \beta C_t(d, e), \qquad \alpha + \beta = 1. \quad (3)$$

Eligibility: The endpoint filter sets $A(d, e) = 1$ for DNS, NTP, update, or vendor-cloud communications, using port, protocol, and name-substring rules. Vendor-cloud includes any remaining FQDN, while private, reserved, and link-local IP literals are excluded. The filter selects endpoint formats and service categories, so resolved attacker domains can also qualify.

Breadth and persistence. Breadth $C_s = |S_{d,e}|/|ES_d|$ measures the fraction of sites observing device type d that report endpoint e. Let $D_{d,e}$ contain the UTC observation dates of (d, e) across sites, and D_d the dates of all observations of d. With pooled observation counts $n_{d,e}$ and n_d, temporal confidence, used here as a measure of persistence, combines day coverage and relative frequency:

$$C_t = 0.7\frac{|D_{d,e}|}{|D_d|} + 0.3\frac{n_{d,e}}{n_d} \in [0, 1]. \quad (4)$$

The 0.7/0.3 split weights day coverage above pooled volume. Counts are pooled without per-site normalization, so a single reporter can supply the whole volume term (at most $0.3\beta = 0.12$ of the score) and, by reporting on every active day of d, the whole day-coverage term ($0.7\beta = 0.28$). C_t therefore enters Criterion 1 only through $C_t \leq 1$: the split changes how much persistence a benign fact needs, not the safety bound. The split is fixed rather than tuned; we sweep only θ and α (Sec. VI-F1).

Parameter derivation. The weights are not free. Since $\alpha + \beta = 1$, only (α, θ) remain, and a single quantity links them to protection, the *breadth margin*

$$f^\star = \frac{\theta - \beta}{\alpha} = 1 - \frac{1 - \theta}{\alpha}. \quad (5)$$

Given eligibility and quorum, Eq. 3 admits a fact whose reporters hold raw breadth share c and whose persistence is C_t if and only if

$$c \;\geq\; f^\star + \frac{\beta}{\alpha}(1 - C_t). \quad (6)$$

With $C_t = 1$ this reduces to $c \geq f^\star$, so $f^\star$ has two readings: it is the largest adversarial share the score alone can absorb, and the smallest breadth at which a benign fact can pass even with perfect persistence. The ratio β/α sets how much additional breadth a persistence deficit costs. Raising θ at fixed α raises $f^\star$; raising α at fixed θ raises $f^\star$ and lowers β/α. A larger $f^\star$ gives more protection but requires more breadth from benign facts (less recall); Sec. VI-F1 measures this trade-off. At $(\alpha, \theta) = (0.6, 0.65)$, $f^\star = 5/12 \approx 0.417$ and $\beta/\alpha = 2/3$: a fact reported on every active day of d but with negligible volume share ($C_t \approx 0.7$) needs $c \geq 0.617$, i.e., seven of ten eligible sites.

Criterion 1 (Admission design constraint, raw breadth)**.** If malicious contributors hold at most raw breadth share f_s (the unweighted share $|S_{d,e}|/|ES_d|$) of the eligible population and an endpoint fact is reported only by them, then $C_s \leq f_s$ and $C_t \leq 1$, so

$$score(d, e) \leq \alpha f_s + \beta = 1 - \alpha(1 - f_s). \quad (7)$$

Requiring this upper bound to fall strictly below θ constrains the parameters to $\alpha > (1 - \theta)/(1 - f_s)$, equivalently $f_s < f^\star$ (Eq. 5).

At $\theta = 0.65$ and $f_s = 0.30$ this requires $\alpha > 0.5$. Choosing $\alpha = 0.6$ gives an upper bound of 0.58 and rejects adversary-only evidence for raw-breadth shares below $5/12$. The guarantee holds per device type, and the bound is a supremum: it is approached only if $C_t \to 1$, which requires the adversary to cover every active day of d and dominate its volume while honest observations of d exist, so a share of exactly $5/12$ is also rejected. In counts, with K adversarial and h honest reporting sites for d, the score alone rejects every adversary-only fact if $K \leq \frac{\theta+\alpha-1}{1-\theta}\, h$, that is, $K \leq \frac{5}{7}h$ at the operating point; above this ratio admission becomes possible, depending on the adversary's persistence and volume. Three colluders thus require at least five honest sites at the margin

and at least seven at the declared share $f_s = 0.30$. Device types observed by few sites are therefore the binding case: with $h \leq 2$, the smallest non-zero adversarial share is $1/3 > f_s$, and the quorum $m = 2$, not the score, rejects single-source facts.

Why $f_s = 0.30$. Only one statement about f_s is derived: Criterion 1 protects every share below $f^\star$, so any budget $f_s < f^\star$ is consistent with the operating point. The value 0.30 is an assumption, a planning budget rather than a measured prevalence, chosen on three grounds. First, it leaves a margin of $f^\star - f_s = 7/60 \approx 0.117$, so a share that exceeds the budget by less than this margin is still rejected. Second, it lies below the $1/3$ fault fraction tolerated by classical Byzantine agreement ($n \geq 3f+1$) [2], [3]; this is an order-of-magnitude reference only, because the DIB guard is a threshold on reporting share, not an agreement protocol. Third, the budget covers two populations with different empirical anchors. For colluding members (A2), the share is a governance property of the consortium, for which the Byzantine bound is the natural reference. For honest sites that report traffic of compromised devices (A1), it is a prevalence, and measurement studies give no per-type value to match: Mirai peaked at about 600,000 infections without a per-type share [1]; 1.3% of devices in homes seen scanning (0.37% of homes) were compromised through an EternalBlue backdoor, and scan data rarely reveal compromise [4]; and 28.25% of 1,362,906 deployed devices had at least one known vulnerability, with per-vendor rates from below 0.5% to 100% [5]. Vulnerable is not compromised, so 0.30 is conservative against measured compromise and of the same order as measured vulnerability prevalence.

A probabilistic reading makes the budget explicit. If n devices of type d share a site and each is compromised independently with probability p, the site reports compromised traffic with probability $q = 1 - (1-p)^n$; for $p = 0.10$ and $n = 4$, $q = 0.34$. If each of the N_d sites observing d is adversarial independently with probability q, admission of an adversary-only fact becomes possible once $K \geq \lceil 5N_d/12 \rceil$. For $q = 0.10$ this event has probability 1.6×10^{-3} at $N_d = 10$, 6.0×10^{-5} at $N_d = 20$, and 3.7×10^{-9} at $N_d = 50$; for $q = 0.30$ it is 0.15, 0.11, and 0.048. The declared budget covers $K \leq \lfloor 0.30 N_d \rfloor$ (three sites at $N_d = 10$), so f_s is better read as a quantile of the compromise distribution than as its mean. Correlated sites (shared firmware, shared vendor cloud) make the independent tail an underestimate.

Sybil-aware variants. Raw breadth counts identities, so fabricated ones inflate it. Trust weighting replaces C_s with

$$C_s^{trust} = \frac{\sum_{i \in S_{d,e}} w_i}{\sum_{i \in ES_d} w_i}, \qquad w_i = \min(1, b_i / b_{ref}),$$

Here, b_i counts site i's distinct contributed facts across device types, and b_{ref} is their median in a frozen clean snapshot. Only b_{ref} is frozen, so current b_i includes new identities and padding. Clustering instead joins sites at Jaccard endpoint-set similarity ≥ 0.8 and computes breadth over the connected components. Sec. IV-D discusses which guarantee applies to each variant, and Sec. VI-F1 compares them under identity inflation.

TABLE IV
ADMISSION PARAMETERS. D: DERIVED; A: ASSUMED; U: UNTUNED.

Param.	Basis	Effect of a change
$f_s = 0.30$	A: budget below $f^\star$ and below $1/3$; prevalence anchors (Sec. IV-C)	not used by the score; needs $f^\star > f_s$
$\theta = 0.65$	D with α: Criterion 1 needs $\theta > \beta + \alpha f_s = 0.58$. [NON GIUSTIFICATO NEGLI ALLEGATI: 0.65 within $(0.58, 1)$]	higher: larger $f^\star$, lower recall; ≤ 0.58 voids the criterion
$\alpha = 0.6$	D: $\alpha > (1-\theta)/(1-f_s) = 0.5$. [NON GIUSTIFICATO NEGLI ALLEGATI: 0.6 within $(0.5, 1]$]	higher: larger $f^\star$, persistence matters less; ≤ 0.5 voids the criterion
$\beta = 0.4$	D: $\beta = 1 - \alpha$	as for α
$m = 2$	D: with $h \leq 1$ honest observers the score alone can admit a single reporter	$m = 1$ admits single colluders; $m = 3$ rejects every fact with two reporters
0.7/0.3	U: fixed, not swept; does not affect Criterion 1. [NON GIUSTIFICATO NEGLI ALLEGATI: 0.7/0.3]	changes the persistence a benign fact needs (Eq. 6)

TABLE V
THREATS, GOAL AT RISK, AND DIB'S RESPONSE. G3 HOLDS UNDER EVERY THREAT, GIVEN AS1, AS4, AND AS5.

Threat	Goal	Response; residual risk
A1	G2	counted in f_s; eligibility rejects IP-literal peers, but resolved attacker names can enter review
A2 within AS2	G2	quorum and Criterion 1 (raw breadth)
A2 beyond AS2	G2	no guarantee; trust weighting and clustering are heuristics
A3	G1, G2	identical evidence; requires local review or out-of-band information
A4	avail.	withdrawal creates no authorization; restoration needs the administrator and a fresh commit
Disconnection	G3	ordered pending update applied on reconnection; no time bound
Faulty evidence service	G2	holds no local authorization state

Parameter rationale. Table IV states the basis of each value and the effect of a change. Safety fixes only the constraint $f^\star > f_s$; the operating point keeps one further degree of freedom, β/α, which affects recall but not protection. The θ, α sweep (Sec. VI-F1) characterizes this trade-off and was not used to select the operating point.

D. Security Analysis

Table V relates the mechanisms above to the goals and threats of Sec. III.

G3. G3 follows from the lifecycle guards (I1–I3, Eq. 1), which hold for any content of shared evidence; A1–A4 therefore cannot create local authorization under AS1, AS4, and AS5. A faulty evidence service can delay withdrawal or issue unfounded disputes and restorations, but a restoration returns records to MonitorOnly (Table II), so it cannot make a fact exportable either. A site that misses an episode applies the latest ordered update on reconnection, without a time bound (AS6).

G2. G2 is the guarantee of Criterion 1 and holds only under AS2 and with raw breadth. Under trust weighting, an adversary-only fact has $C_s^{trust} = W$, where $W = \sum_{i \in S_{d,e}} w_i / \sum_{i \in ES_d} w_i$ is the adversaries' weighted share, so the same algebra rejects it whenever $W < f^\star$. The

weights, however, grow with b_i, which counts the facts that site i itself contributes: a member that contributes many facts reaches full weight while honest sites with fewer contributions keep lower weights, so W can exceed the raw share, and a fact can pass with a raw share below $f^\star$. Results obtained with trust weighting are therefore not covered by Criterion 1, and clustering has no analogous bound. Fabricated identities beyond AS2 and A1 traffic reported by more than a fraction f_s of observers fall outside G2. Admission failure creates a false proposal, not a rule (G3).

G1, A3, and A4. Candidate selection gives no guarantee about intent: under A3, separating legitimate from malicious change requires local review or out-of-band information, and Active facts that later fail admission keep their approval and receive a review flag. A4 affects availability only: withdrawal removes rules but cannot install them, and suspending a fact after one or after two distinct reporters trades withdrawal speed for robustness to a single false notice (Sec. VI-D).

V. Implementation and Evaluation Method

The distributed prototype separates shared evidence from site-local decisions into distinct services (Sec. VI-B). Registry transactions apply per-fact dispute/restore changes atomically, with up to ten retries for conflicting writes. The implementation uses Python and FastAPI, with SQLAlchemy 2 and SQLite for persistence.

To test whether lifecycle changes reach gateway enforcement, we run unmodified osMUD commit `852918e` in a privileged Docker container with the OpenWrt 23.05.5 root filesystem. Restarting osMUD after each policy change applies MUD ACLs as nftables rules. We record ACEs, effective rules, registry/osMUD state, and a live TCP probe for each transition. Exports are unsigned and signature validation is disabled.

Candidate-selection experiments use three traffic datasets. UNSW-IoTraffic [8] supplies 27 device types and 28 traffic-derived reference profiles; its single capture is shuffled and partitioned round-robin into ten pseudo-sites (seed 42 unless stated). Mon(IoT)r [30] provides US and UK captures after collapsing VPN variants; YourThings [31] adds a third deployment for cross-lab comparisons (Sec. VI-E2). We retain device-initiated flows with a port and global peer or public name. UNSW associates IPs with same-site HTTP Host and TLS Server Name Indication (SNI) within 24 hours; Mon(IoT)r uses cumulative DNS.

Using these observations, we assess sharing by comparing receiver-only evidence (*local-only*) with all pooled facts (*pooled union*). Successively adding a two-reporter quorum, the score threshold, and endpoint eligibility isolates filtering effects, while *ranked union* selects the highest-scoring pooled facts at matched review budgets.

We then test robustness with captured and synthetic inputs. The A1 replay injects 165 malicious observations forming 59 endpoint facts at $k = 1, \ldots, 10$ pseudo-sites, using *frequency filtering* ($n_{d,e} \geq 2$ pooled observations) as a baseline. Further tests inject fabrications, resolved-name and port masquerading, Sybil identities (200–3,200 over 20–400 days), and synthetic rollouts, with fabricated endpoint sets diversified by 0/10/25/50% of a baseline pool. For identity inflation, *reputation-weighted voting (RWV)* provides a comparison requiring weighted support above 0.65, with frozen pre-attack weights and weight 0.1 for unseen identities.

To measure agreement with reference behavior, we match predictions on device, direction, normalized protocol, peer, and port, treating port 0 and unknown protocol as wildcards and CIDR ranges by membership. Micro metrics pool true/false positives and negatives; UNSW macro metrics average over its 28 reference profiles.

For reproducibility, the anonymized repository supplied with the submission contains configurations, input hashes, adapters, sampling details, generated MUD files, gateway states and probes, TLA+ specifications and logs, matched ablations, parameter and identity-inflation grids, and regression evidence.

VI. Evaluation

We assess whether DIB preserves local authorization during withdrawal and recovery, how fast both are under delay and loss, and what candidate selection achieves on captured traffic. Timing experiments run ten site services and an evidence service in Docker on one 16-vCPU KVM node, with `tc netem` on every container; hypotheses were fixed before the runs.

A. Authorization and Recovery

The TLA+ model represents three sites and two facts, distinguishing the dispute opener, confirmer, and bystander. Exhaustive exploration of 4,311,852 states finds no violation of I1–I3 or the export checks: only local commits create fresh authorization, export requires it, and disputes invalidate it without affecting unrelated facts. With one of three sites disconnected and local revoke and restore enabled, 48,960 states show no violation. A model of the implemented non-atomic query and commit protocol (two sites, one fact) explores 402,633,492 states with three evidence events and partitions without violations; removing any of its five corrections produces one. Adding failed evidence reads, abandoned reconcile runs, and site crash with restart cleanup, safety holds with three events (154,363,430 states), partitions, two lost deliveries, quorum two, two facts, and three sites (712,287,745 states); removing the cleanup produces a violation. Strict suspension at every reachable site holds without failures; with failed reads, a site left behind is repaired by anti-entropy. These checks are exhaustive only within their finite configurations; they do not cover gateway timing, concurrent requests per site, three-event convergence with failures, or linearizability.

To identify which safeguards prevent failures, we remove six lifecycle guards in separate model variants, M1–M6. Each produces a distinct authorization failure involving grant handling, site confinement, revocation origin, or export control (Table VI). A separate model of the mTLS authorization rules, extracted from the service code, checks role and site confinement; its ten base configurations find no counterexample and six mutants each violate the property they remove. **[PLACEHOLDER: scope on revocation timing and multi-SAN certificates, to confirm.]**

TABLE VI
GUARD-REMOVAL MUTATIONS M1–M6 AND THEIR COUNTEREXAMPLES. A SEPARATE CONTROL WITH OPERATOR-COMMIT DISABLED LEAVES 2,076,196 REACHABLE STATES, NONE ACTIVE.

ID	Property	Guard removed	Counterexample
M1	Grant coherence	restore recreates grant	authorization without commit
M2	I2 site confinement	cross-site commit	remote commit alters s'
M3	I2 local-revoke confinement	local-revoke fans out	remote site's record changes
M4	I3 global restore preserves local revoke	restore ignores revocation origin	local veto erased
M5	I3 local-restore conservative	local-restore ignores open dispute	site escapes live dispute
M6	Export requires Active	disputed export	ACE emitted while Disputed

The registry tests exercise these rules through one- and two-dispute episodes, repeated restoration, and local vetoes recorded before or during withdrawal. Among three restoration policies, only DIB prevents export of a disputed fact without a new commit while preserving every local veto: reusing approvals exports the fact at 12 of 18 non-vetoing sites, and resetting all records to review erases all six vetoes. Repeated score changes leave decision states and MUD export unchanged. All ten OpenWrt/osMUD gateway cases apply the exported policies as expected: MonitorOnly produces no rule, the first dispute removes the nftables rules, and access resumes only after a global restore and a fresh commit.

B. Recovery After Disconnection

When a site becomes unreachable, the service retains only the latest pending target for each fact and applies it on reconnection through the same idempotent path, using a monotonic per-fact sequence number; a restore target therefore invalidates an old Active approval even if the preceding dispute never reached the site. We kill one site, complete k withdrawal-and-restore episodes at the others, restart it, and measure the time until it converges, for $k = 1$, 10, and 50 (50 at *lan* only), reconciliation interval $T \in \{5, 15\}$ s, with and without mutual TLS, in three network profiles (*lan*, *wan*: 80 ms and 1% loss per direction, *degraded*: 200 ms and 5%). Each of the 28 cells has 30 trials (two series of 10 and 20 trials with different seeds, pooled). The pre-registered bound is $1.5 + 0.1T + \max(5, D_{run})$ s, 7.0–8.6 s.

The median convergence is 0.6–1.4 s at *lan*, including 50 missed episodes (0.7–1.4 s), 1.4–2.1 s at *wan*, and 2.4–4.1 s at *degraded*; it stays below the bound in all 28 cells. All 834 completed trials (840 planned; six excluded for a refused setup request) end with every site in the MonitorOnly state and no transient record. At *degraded*, 3 of 234 trials exceed the bound (by 0.1 to 4.0 s); in the one we traced, with mutual TLS, the first reconciliation attempt timed out in the TLS handshake (5 s) and the second succeeded. The reconciliation call itself takes 71 ms on average and at most 105 ms.

C. Withdrawal Under Emulated Network Delay and Loss

A generator on the node sends a dispute and timestamps each site's `/apply_fanout` log line with the clock that stamped the dispute, so the withdrawal time of the last site excludes the response path. Each cell crosses sequential and concurrent fan-out (1 or 10 sites at a time) with the presence (C) or absence (D) of mutual TLS; the *degraded* profile ($R = 400$ ms round trip, 5% loss per direction) has two replicas of 50 episodes per cell, run on a deployment whose containers were verified to execute the evaluated service.

TABLE VII
WITHDRAWAL AT *degraded*: MEDIAN TIME OF THE LAST SITE (MS) AND SHARE OF LATE DELIVERIES PER SITE, DELIVERY-COST MODEL AGAINST TWO REPLICAS (R1, R2) OF 50 EPISODES. LATE: MORE THAN 0.75 ROUND TRIPS BEYOND THE LOSSLESS TIME.

Cell	Quantity	Model	R1	R2
D, 10 sites	last site (ms)	2000	1621	2012
C, 10 sites	last site (ms)	2800	2823	2821
D, 1 site	last site (ms)	10600	11517	10774
C, 1 site	last site (ms)	17200	17215	16701
D, 10 sites	late share	0.179	0.189	0.204
C, 10 sites	late share	0.280	0.314	0.340

We explain the delays with a delivery-cost model that has no fitted parameter: an attempt is a TCP handshake, with mutual TLS a TLS round trip and the client certificate flight, and a two-segment request; a lost segment is retransmitted after $R + \max(2R, 0.2)$ s, which for $R \geq 0.2$ s exceeds the 1 s per-phase timeout, so one loss fails the attempt; the periodic reconciliation then brings each site to the disputed state. The model was checked out of sample in a network-namespace testbed (six conditions, within 1.7 points) and on the deployment (Table VII). Without mutual TLS it predicts the share of late deliveries per site within 3.4 points in five conditions (two *degraded* replicas and four further conditions with $R = 0.12$–0.30 s and loss 4–8%) and the median of the last site within 9% under sequential fan-out. With mutual TLS it is a lower estimate: the measured share exceeds it by 3–7 points in four of five conditions. In the testbed, sequential fan-out took 3.1–7.1 times the median withdrawal time of concurrent fan-out, and every site reached the disputed state in 3,280 episodes with loss; the service therefore fans out concurrently by default.

D. Suspension Policy and Availability

With immediate suspension, one member's requests withdraw the disputed facts across ten sites and take exports from the approved ACEs to zero, while the services keep answering; under two-reporter suspension the first report is retained and the second opens the dispute, duplicate reports add no votes, and local vetoes recorded during withdrawal survive restoration with fresh commits required for export. **[PLACEHOLDER: withdrawal-time and read-throughput figures to remeasure on the final service.]**

E. Candidate Selection on Captured Traffic

In UNSW, only 55 of the 564 reference ACEs across 28 profiles remain observable after address filtering. DIB stages 36 of the observable ACEs, retaining 65.5% of observable behavior. Pooling helps at cold start (macro F1 0.112 ± 0.002 for ten pseudo-sites after 30 days, against 0.022 ± 0.005 for one), but this reflects a larger sample, not agreement across

TABLE VIII
MATCHED COLD-START ABLATION: EACH RECEIVER USES THE OTHER TWO DEPLOYMENTS AS SOURCES. Q=TWO-SITE QUORUM; S=SCORE WITH RAW BREADTH ($\alpha = 0.6$, $\beta = 0.4$, $\theta = 0.65$, NO TRUST WEIGHTS); C=ENDPOINT ELIGIBILITY; N=CANDIDATES; COV.=DEVICE COVERAGE; P/R/F1=MACRO AGREEMENT WITH RECEIVER TRAFFIC OVER SIX DEVICE TYPES. FULL-DIB 95% F1 CIS (US/UK/YT): [.033,.198]/[.044,.186]/[.116,.384].

Receiver	Filter	N	Cov.	P	R	F1
US	Union	1005	100%	.322	.358	.327
	Q	42	83.3%	.750	.079	.139
	QS	40	83.3%	.750	.076	.135
	DIB (QSC)	36	83.3%	.750	.065	.116
UK	Union	767	100%	.279	.449	.320
	Q, QS	48	83.3%	.745	.078	.138
	DIB (QSC)	43	83.3%	.784	.064	.115
YT	Union	1387	100%	.059	.334	.095
	Q	177	100%	.173	.282	.208
	QS	146	100%	.257	.282	.268
	DIB (QSC)	107	100%	.286	.223	.247

independent networks: the pseudo-sites are shards of one capture.

1) Candidate Review Volume: The independent Mon(IoT)r US and UK captures share 26 device types. Of 24,886 distinct pooled facts, 24,046 occur at only one site and 840 at both, so the two-site quorum produces the largest reduction; the score threshold narrows the queue to 697 facts and endpoint eligibility to 462: 98.1% fewer than pooling and 33.7% fewer than quorum with scoring.

2) Proposals for a New Receiving Site: A new receiving site must not use its own observations to select proposals, so we exclude the receiver from reporter sets and counts. YourThings (YT) [31] supplies a third deployment, and a fixed six-entry label mapping aligns the device types present in all three. Each receiver uses the other two deployments as sources (Table VIII); precision, recall, and F1 measure macro per-device agreement with receiver-observed endpoints.

DIB reduces candidate counts by 96.4% at US, 94.4% at UK, and 92.3% at YT and raises precision to 0.75/0.78/0.29 from 0.32/0.28/0.06 for the pooled union. The reduction trades coverage for review effort: the union contains more receiver-observed endpoints and has the higher macro F1 at US and UK, but needs 5.46/4.31/28.31 inspected entries per receiver-observed endpoint, against 1.03/1.16/2.89 for DIB. Admission and ordering serve different purposes: ranking limits review to a budget, whereas admission excludes adversary-only evidence under the raw-breadth Criterion 1; we recommend threshold-then-rank. These comparisons describe filter behavior on the selected captures; only six device types are common to the three deployments and the 95% F1 intervals overlap across receivers.

F. Adversarial Observations and Fabricated Evidence

We inject captured malicious traffic and fabricated reports into the ten UNSW pseudo-sites, whose partition fixes the reporting population and lets us control the raw malicious breadth share f_s of Criterion 1. This does not establish reporter independence in a real consortium; that remains a governance assumption (Sec. III-B). DIB stages none of the 59 captured A1 facts, which pooled union and frequency filtering stage in full. At $f_s = 0.30$ the largest score passing quorum is 0.562 over 120 days, below θ, and an exhaustive worst case with raw breadth reaches 0.579, within the bound of 0.58. The guarantee is conditional: it holds up to $f_s = 0.30$, and replacing IP literals with resolvable names raises admission from 0/150 to 21/150 configurations; a fabrication at $f_s = 0.50$ reaches 0.663 (Sec. VI-F1 treats identity inflation).

1) Parameter Sensitivity, Identity Inflation, and Drift: The operating point chosen from the adversarial bound is not the one that maximizes traffic agreement: sweeping $\theta \in [0.50, 0.80]$ and $\alpha \in [0.4, 0.9]$ on Mon(IoT)r yields a best macro F1 of 0.071, against 0.054 at the chosen setting. Identity inflation deliberately violates the malicious-share assumption: raw counting admits the fabrication in 45 of 48 representative configurations, trust weighting and clustering reject them, and padding fabricated identities with real endpoints defeats clustering at the extreme (score 0.905). In a synthetic rollout over 162 device-type/adoption pairs, 69 pairs enter review by day 120 (median first admission: day seven); distinguishing a rollout from a slow compromise requires operator review.

VII. DISCUSSION

Recovery requires approval validity and revocation origin, whether represented through states or history. The mutations (Table VI) and the restoration-policy ablation (Sec. VI-A) expose failures when this information or its checks are omitted. The review process still requires evaluation with operators.

Candidate selection can adapt without changing local authorization or recovery. Quorum accounts for most queue reduction at US/UK; ordering explains the advantage over unranked pooling. Threshold-then-rank suits deployments that maintain the bounded raw-breadth share assumption of Criterion 1. Trust weighting and clustering mitigate tested identity inflation but fail under padding. Ranked union yields slightly more receiver-observed endpoints at matched budgets, but no tested policy establishes benignity or necessity. Review capacity should inform the retention window W, whose practical value remains open.

Local control does not eliminate withdrawal's availability costs. One reporter can interrupt service under immediate suspension; requiring two preserves permissions until corroboration but delays withdrawal if no second report arrives. Both policies remain vulnerable to collusion, and the prototype lacks dispute rate limits and reputation penalties. Unreachable gateways can retain stale rules until reconnection, with no established withdrawal deadline while unreachable (after reconnection, the median convergence stayed within its bound in every measured cell).

The shared evidence service is a throughput bottleneck and single point of failure for candidate flow and withdrawal propagation. It holds no local authorization state: failure can delay withdrawal but cannot itself grant or revoke local permissions. Replication and recovery remain deployment concerns. Co-located experiments emulate delay and loss on one host pair rather than measure a real wide-area network, and do not evaluate production workloads; finite models assume authenticated callers, and gateway tests disable signature validation.

Deployment requires the authentication, roles, and signing integration in Sec. III-B.

The pseudo-site partition and six-type alignment restrict generalization. Coverage of fleets using these mechanisms remains unverified.

VIII. Conclusion

This paper presented DIB for managing locally authorized MUD policies from shared IoT observations. Finite-model checks and guard-removal mutations assess its authorization lifecycle; OpenWrt/osMUD tests demonstrate enforcement. Outage experiments show that one collapsed update preserves local vetoes and invalidates stale approvals after a missed withdrawal and restoration episode. Candidate-selection and suspension experiments quantify review volume and availability costs. Future work will evaluate operator review, mechanisms to bound gateway withdrawal time, and recovery of the shared evidence service.

0pt plus .5pt 0pt

References

[1] M. Antonakakis *et al.*, "Understanding the Mirai Botnet," in *Proc. 26th USENIX Security Symp.*, 2017, pp. 1093–1110.

[2] L. Lamport, R. Shostak, and M. Pease, "The Byzantine Generals Problem," *ACM Trans. Program. Lang. Syst.*, vol. 4, no. 3, pp. 382–401, 1982.

[3] M. Castro and B. Liskov, "Practical Byzantine Fault Tolerance," in *Proc. 3rd USENIX Symp. Operating Systems Design and Implementation (OSDI)*, New Orleans, LA, USA, Feb. 1999, pp. 173–186.

[4] D. Kumar, K. Shen, B. Case, D. Garg, G. Alperovich, D. Kuznetsov, R. Gupta, and Z. Durumeric, "All Things Considered: An Analysis of IoT Devices on Home Networks," in *Proc. 28th USENIX Security Symp.*, 2019, pp. 1169–1185.

[5] B. Zhao, S. Ji, W.-H. Lee, C. Lin, H. Weng, J. Wu, P. Zhou, L. Fang, and R. Beyah, "A Large-Scale Empirical Study on the Vulnerability of Deployed IoT Devices," *IEEE Trans. Dependable Secure Comput.*, vol. 19, no. 3, pp. 1826–1840, May/Jun. 2022.

[6] E. Lear, R. Droms, and D. Romascanu, "Manufacturer Usage Description Specification," RFC 8520, IETF, Mar. 2019.

[7] A. Hamza, D. Ranathunga, H. Habibi Gharakheili, M. Roughan, and V. Sivaraman, "Clear as MUD: Generating, Validating and Applying IoT Behavioral Profiles," in *Proc. ACM SIGCOMM Workshop IoT S&P*, 2018.

[8] A. Sivanathan *et al.*, "Classifying IoT Devices in Smart Environments Using Network Traffic Characteristics," *IEEE Trans. Mobile Comput.*, vol. 18, no. 8, pp. 1745–1759, 2019.

[9] A. Hamza *et al.*, "Verifying and Monitoring IoTs Network Behavior Using MUD Profiles," *IEEE Trans. Dependable Secure Comput.*, vol. 19, no. 1, pp. 1–18, 2022.

[10] A. Hamza, H. Habibi Gharakheili, T. A. Benson, and V. Sivaraman, "Detecting Volumetric Attacks on IoT Devices via SDN-Based Monitoring of MUD Activity," in *Proc. ACM SOSR*, 2019.

[11] F. Corno and L. Mannella, "A Gateway-based MUD Architecture to Enhance Smart Home Security," in *Proc. SpliTech*, 2023, pp. 1–6.

[12] osMUD Project, "osMUD: Open Source MUD Manager," https://osmud.org. (Accessed Jul. 24, 2026.)

[13] J. L. Hernández-Ramos, S. N. Matheu, A. Feraudo, G. Baldini, J. Bernal Bernabe, P. Yadav, A. Skarmeta, and P. Bellavista, "Defining the Behavior of IoT Devices Through the MUD Standard: Review, Challenges, and Research Directions," *IEEE Access*, vol. 9, pp. 126265–126285, 2021.

[14] S. N. Matheu, J. L. Hernández-Ramos, S. Pérez, and A. F. Skarmeta, "Extending MUD Profiles Through an Automated IoT Security Testing Methodology," *IEEE Access*, vol. 7, pp. 149444–149463, 2019.

[15] T. D. Nguyen *et al.*, "DÏoT: A Federated Self-learning Anomaly Detection System for IoT," in *Proc. IEEE ICDCS*, 2019, pp. 756–767.

[16] E. Vasilomanolakis, S. Karuppayah, M. Mühlhäuser, and M. Fischer, "Taxonomy and Survey of Collaborative Intrusion Detection," *ACM Comput. Surv.*, vol. 47, no. 4, Art. 55, 2015.

[17] A. Feraudo, P. Yadav, V. Safronov, D. A. Popescu, R. Mortier, S. Wang, P. Bellavista, and J. Crowcroft, "CoLearn: Enabling Federated Learning in MUD-Compliant IoT Edge Networks," in *Proc. ACM EdgeSys*, 2020, pp. 25–30.

[18] L. Morgese Zangrandi, T. van Ede, T. Booij, S. Sciancalepore, L. Allodi, and A. Continella, "Stepping out of the MUD: Contextual Threat Information for IoT Devices with Manufacturer-Provided Behavior Profiles," in *Proc. ACSAC*, 2022, pp. 467–480.

[19] C. Wagner, A. Dulaunoy, G. Wagener, and A. Iklody, "MISP: The Design and Implementation of a Collaborative Threat Intelligence Sharing Platform," in *Proc. ACM WISCS*, 2016, pp. 49–56.

[20] OASIS CTI TC, "STIX Version 2.1," OASIS Standard, Jun. 2021.

[21] S. D. Kamvar, M. T. Schlosser, and H. Garcia-Molina, "The EigenTrust Algorithm for Reputation Management in P2P Networks," in *Proc. WWW*, 2003.

[22] A. Jøsang, R. Ismail, and C. Boyd, "A Survey of Trust and Reputation Systems for Online Service Provision," *Decision Support Systems*, vol. 43, no. 2, pp. 618–644, 2007.

[23] M. Sloman, "Policy Driven Management for Distributed Systems," *J. Netw. Syst. Manage.*, vol. 2, no. 4, pp. 333–360, 1994.

[24] A. Clemm, L. Ciavaglia, L. Z. Granville, and J. Tantsura, "Intent-Based Networking: Concepts and Definitions," RFC 9315, IETF, Oct. 2022.

[25] E. Al-Shaer and H. Hamed, "Modeling and Management of Firewall Policies," *IEEE Trans. Netw. Serv. Manage.*, vol. 1, no. 1, pp. 2–10, Apr. 2004, doi: 10.1109/TNSM.2004.4623689.

[26] A. Chowdhary, A. Sabur, N. Vadnere, and D. Huang, "Intent-Driven Security Policy Management for Software-Defined Systems," *IEEE Trans. Netw. Serv. Manage.*, vol. 19, no. 4, pp. 5208–5223, 2022, doi: 10.1109/TNSM.2022.3183591.

[27] A. dos Santos Pires, F. M. Matos, A. Santos, D. Pessoa, *et al.*, "PipeConf: An Integrated Architecture for the Automated Configuration of Network Assets," *IEEE Trans. Netw. Serv. Manage.*, vol. 19, no. 3, Sep. 2022, doi: 10.1109/TNSM.2022.3195382.

[28] A. Vergütz, B. V. dos Santos, B. Kantarci, and M. Nogueira, "Data Instrumentation From IoT Network Traffic as Support for Security Management," *IEEE Trans. Netw. Serv. Manage.*, vol. 20, no. 2, pp. 1392–1404, Jun. 2023, doi: 10.1109/TNSM.2022.3233673.

[29] C. K. Rath, A. K. Mandal, and A. Sarkar, "Blockchain-based Dynamic MUD Profiles for Tamper-proof IoT Access Control," *J. Inf. Secur. Appl.*, vol. 95, Art. 104273, 2025, doi: 10.1016/j.jisa.2025.104273.

[30] J. Ren, D. J. Dubois, D. Choffnes, A. M. Mandalari, R. Kolcun, and H. Haddadi, "Information Exposure From Consumer IoT Devices: A Multidimensional, Network-Informed Measurement Approach," in *Proc. ACM IMC*, 2019, pp. 267–279, doi: 10.1145/3355369.3355577.

[31] O. Alrawi, C. Lever, M. Antonakakis, and F. Monrose, "SoK: Security Evaluation of Home-Based IoT Deployments," in *Proc. IEEE Symp. Security and Privacy*, 2019.

[32] D. Y. Huang, N. Apthorpe, F. Li, G. Acar, and N. Feamster, "IoT Inspector: Crowdsourcing Labeled Network Traffic from Smart Home Devices at Scale," *Proc. ACM Interact. Mob. Wearable Ubiquitous Technol.*, vol. 4, no. 2, Art. 46, 2020.

[33] W. He, K. Bryson, R. Calderon, V. Prakash, N. Feamster, D. Y. Huang, and B. Ur, "Can Allowlists Capture the Variability of Home IoT Device Network Behavior?" in *Proc. IEEE EuroS&P*, 2024, pp. 114–138, doi: 10.1109/EuroSP60621.2024.00015.

[34] A. Lotto, S. Sciancalepore, A. Brighente, and M. Conti, "FIDEM: A Standard-Compliant Framework for Secure Binding of MUD Profiles to IoT Devices," *arXiv preprint arXiv:2605.29654*, May 2026.

[35] A. Zhang, X. Lee, Z. Zhuang, J. Wei, Y. Fu, and B. Peng, "POLARIS: Cross-Domain Access Control via Verifiable Identity and Policy-Based Authorization," in *Proc. IEEE 24th Int. Conf. Trust, Security and Privacy in Computing and Communications (TrustCom)*, 2025, pp. 1489–1498.

[36] R. Pang *et al.*, "Zanzibar: Google's Consistent, Global Authorization System," in *Proc. USENIX Annu. Tech. Conf. (ATC)*, 2019, pp. 33–46.

[37] M. Richardson, W. Pan, and E. Lear, "Authorized Update to MUD URLs," IETF Internet-Draft `draft-ietf-iotops-mud-acceptable-urls`, work in progress, 2025.

[38] OASIS, "eXtensible Access Control Markup Language (XACML) Version 3.0," OASIS Standard, Jan. 2013.

[39] M. Shapiro, N. Preguica, C. Baquero, and M. Zawirski, "Conflict-Free Replicated Data Types," in *Proc. Int. Symp. Stabilization, Safety, and Security of Distributed Systems (SSS)*, 2011, pp. 386–400.